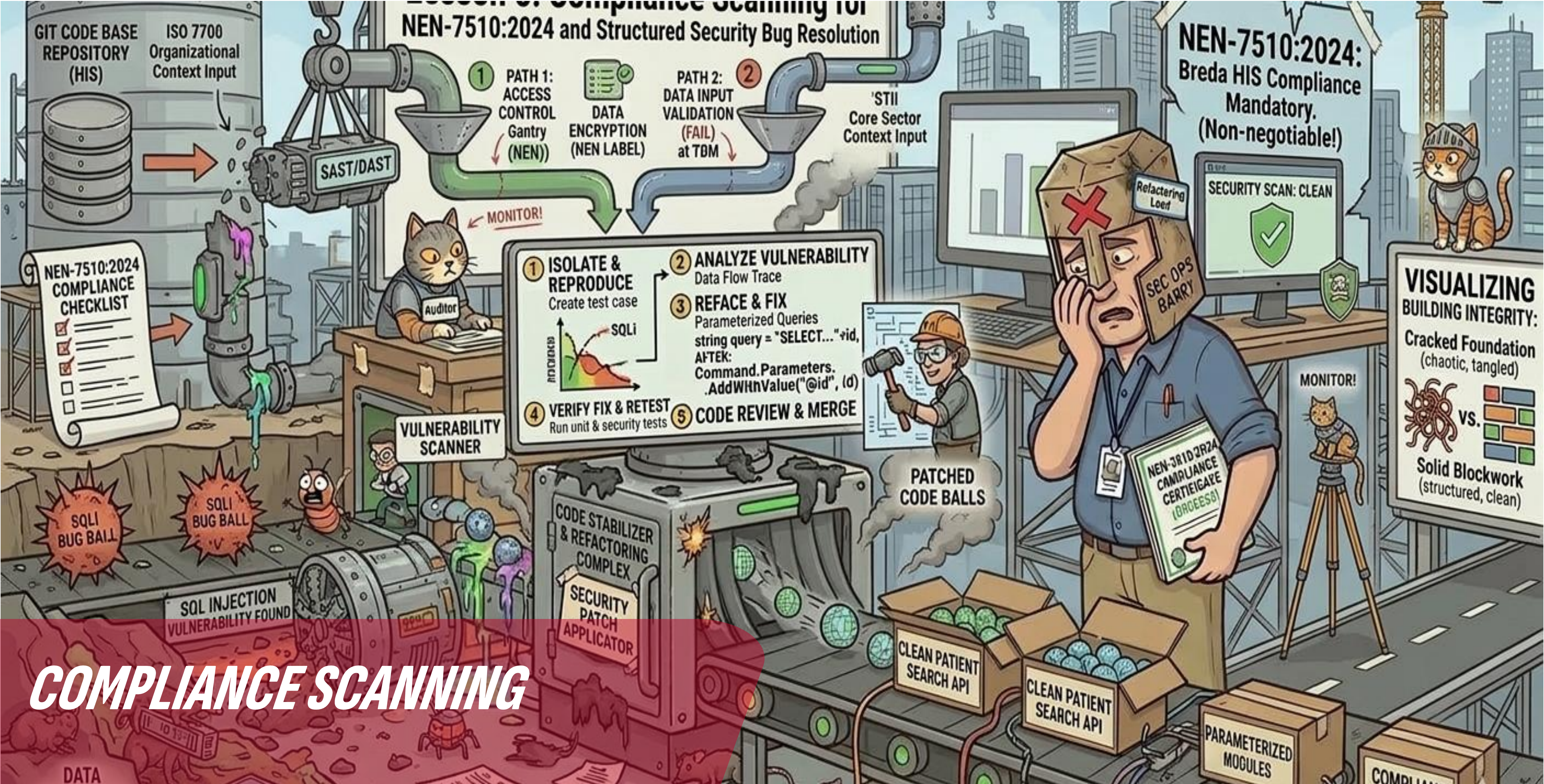






COMPLIANCE SCANNING

WAAR STAAN WE

Workshop	Thema	Deliverable
WS01	Wet- & regelgeving, NEN-7510, audit mindset	Begrippenkader
WS02	Hardening CI/CD pipeline (CodeQL, Dependabot, SBOM)	Beveiligde pipeline
WS03	Healthcare Risk Assessment (risicomatrix, bow-tie)	Risicorapport
WS04	Compliance Scanning (CVE/CVSS, Snyk, security backlog)	Scanrapport + backlog
WS05	Secure Coding & Privacy by Design	Logging + tests
WS06	Formeel auditrapport	Definitief auditrapport

LEERDOELEN

Na deze workshop kun je...

- ✓ Scanuitvoer interpreteren: CVE-ID lezen, CVSS-score ontleden, CWE-categorie duiden
- ✓ Contextuele risicobeoordeling uitvoeren: niet elke CVSS 9.8 is direct kritiek
- ✓ AI-tools verantwoord inzetten voor security review
- ✓ Snyk gebruiken voor SCA, SAST en SBOM-generatie
- ✓ Bevindingen prioriteren
- ✓ Een compliance-ready risicorapport schrijven
- ✓ Koppeling maken naar NEN-7510:2024-2 controls 8.8 en 8.29

Herhaling – Security tooling - SAST

Techniek	Wat het doet	Voorbeeldtools	NEN-7510-2
SAST	Analyseert broncode zonder uitvoering; zoekt patronen van kwetsbaarheden	CodeQL, Snyk Code, Semgrep	8.29, 8.28
SCA	Controleert third-party dependencies op bekende CVE's	Dependabot, Snyk, OWASP Dependency-Check	8.8, 5.22
SBOM	Inventarislijst van alle componenten + versies + licenties	Syft, CycloneDX, snyk sbom	8.8, 5.22
DAST	Test de draaiende applicatie via HTTP/API-aanroepen	OWASP ZAP, Burp Suite	8.29
Fuzzing	Stuurt random/malformed input naar de applicatie om crashes te vinden	AFL++, LibFuzzer, Jazzer (Java)	8.29

Voorbeelden tooling: vooral Snyk

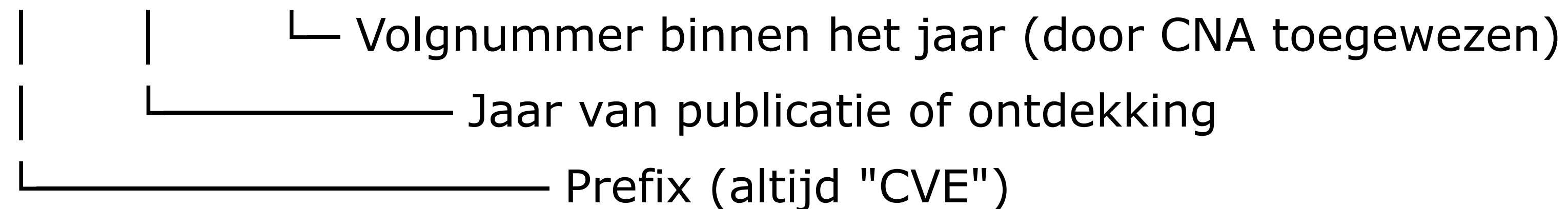
CVE: Common Vulnerabilities and Exposures

Wat is een CVE?

- Een unieke identifier voor een publiek bekende beveiligingskwetsbaarheid
- Beheerd door NIST NVD (National Vulnerability Database) — nvd.nist.gov
 - *note: door ontwikkeling in de VS nu ook een Europese beheerder
- Oorspronkelijk gecoördineerd door MITRE Corporation
- Elke CVE krijgt een CVSS-score, beschrijving, en verwijzingen naar patches

CVE anatomie

- CVE - 2024 - 38819



- **Voorbeeld: CVE-2024-38819**

- *Spring Framework path traversal vulnerability*
 - *een aanvaller kan willekeurige bestanden lezen op de server.*

- **Relevantie voor OpenMRS:**

- OpenMRS gebruikt Spring Framework → deze CVE is direct van toepassing
- NEN-7510 **8.8** vereist dat je een proces hebt om zulke kwetsbaarheden bij te houden en te adresseren

CWE: Common Weakness Enumeration

Wat is een CWE?

- Categorisering van de *oorzaak* (root cause) van een kwetsbaarheid
- Beheerd door MITRE — cwe.mitre.org
- CVE beschrijft *een specifiek geval*; CWE beschrijft *de klasse van het probleem*

CWE-ID	Naam	Voorbeeld in OpenMRS
CWE-89	SQL Injection	Ongesanitiseerde patiëntzoekopdracht
CWE-79	Cross-site Scripting (XSS)	Opslaan en terugsturen van HTML in berichten
CWE-200	Exposure of Sensitive Information	Stack trace met patiëntdata in foutmelding
CWE-287	Improper Authentication	Sessie niet verlopen na uitloggen
CWE-611	XML External Entity (XXE)	Verwerking van HL7/FHIR XML-bestanden
CWE-502	Deserialization of Untrusted Data	Java-objecten via REST-API deserialiseren

CWE: Common Weakness Enumeration

CWE-ID	Naam	Voorbeeld in OpenMRS
CWE-89	SQL Injection	Ongesanitiseerde patiëntzoekopdracht
CWE-79	Cross-site Scripting (XSS)	Opslaan en terugsturen van HTML in berichten
CWE-200	Exposure of Sensitive Information	Stack trace met patiëntdata in foutmelding
CWE-287	Improper Authentication	Sessie niet verlopen na uitloggen
CWE-611	XML External Entity (XXE)	Verwerking van HL7/FHIR XML-bestanden
CWE-502	Deserialization of Untrusted Data	Java-objecten via REST-API deserialiseren

Waarom relevant?

- SAST-tools (CodeQL, Snyk Code) rapporteren bevindingen als CWE's
- NEN-7510 **8.28** (Veilig coderen) koppelt aan CWE-patronen als kennisbasis
- Een CWE-mapping helpt je prioriteren: CWE-89 in een patiëntenportaal = direct kritiek

CVSS v3.1 (Common Vuln Scoring System)

Code	Naam	Opties	Betekenis
AV	Attack Vector	Network (N) / Adjacent (A) / Local (L) / Physical (P)	Hoe ver is de aanvaller verwijderd?
AC	Attack Complexity	Low (L) / High (H)	Hoe moeilijk is de aanval?
PR	Privileges Required	None (N) / Low (L) / High (H)	Welk toegangsniveau is vereist?
UI	User Interaction	None (N) / Required (R)	Moet een gebruiker iets doen?
S	Scope	Unchanged (U) / Changed (C)	Kan de aanval andere componenten raken?
C	Confidentiality	None (N) / Low (L) / High (H)	Impact op vertrouwelijkheid
I	Integrity	None (N) / Low (L) / High (H)	Impact op integriteit
A	Availability	None (N) / Low (L) / High (H)	Impact op beschikbaarheid

Voorbeeld vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H → Score: 9.8 (Critical)

AV:N = via internet bereikbaar, AC:L = geen speciale kennis, PR:N = geen login nodig, C/I/A:H = volledige impact

CVSS v4?

- CVSS v4.0 is in november 2023 uitgebracht door FIRST.
- v3.1 op dit moment in de praktijk nog dominant

	CVSS v3.1	CVSS v4
Release	2019	2023
nvd.nist.gov	Primair	Deels uitgerolt
Snyk, dependabot, GitHub	Standaard output	'In progress'
Z-CERT	Ok	'In progress'
Tooling	Breed	Nog beperkt

Anders in v4:

- Nieuwe granulariteit: Base → Base, Threat, Environmental, Supplemental
- Threat Metrics vervangen de Temporal Metrics
- Specifieke scores voor OT/ICS/veiligheidsinfrastructuur (relevant voor medical devices)
- Betere aansluiting op EPSS (Exploit Prediction Scoring System)

CVSS → NEN-7510

Vb1 - SQL Injection in patiëntenzoekfunctie:

- CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N → Score: 8.8 (High)
- PR:L = aanvaller heeft een regulier gebruikersaccount (b.v. receptionist)
- C:H + I:H = kan patiëntdossiers lezen én aanpassen
- **NEN-7510 impact:** schending van art. 5 AVG (bijzondere categorieën persoonsgegevens)

Vb 2 - Info-disclosure in admin-only endpoint:

- CVSS:3.1/AV:N/AC:H/PR:H/UI:R/S:U/C:L/I:N/A:N → Score: 2.0 (Low)
- PR:H = alleen systeembeheerders hebben toegang
- In een goed beheerd ziekenhuis: effectief risico is laag

LET OP: CVSS meet technische ernst, niet bedrijfsrisico

CVSS Context

- *"We hebben een CVSS 9.8 kwetsbaarheid in onze applicatie!" → Is dit altijd een 5-alarm brand?*
- **Stel deze vragen:**

Vraag	Als het antwoord "ja"	Als "nee"
Is het betreffende component actief in gebruik?	Score blijft hoog	Score effectief lager
Is het endpoint publiek bereikbaar (internet-facing)?	Score blijft hoog	Score effectief lager
Heeft de aanvaller authenticatie nodig die moeilijk te verkrijgen is?	Score effectief lager	Score blijft hoog
Is er een known exploit in het wild?	Verhoog prioriteit	Score blijft nominaal
Raakt het kwetsbare pad patiëntdata of medicatiebeheer?	Verhoog prioriteit	Score blijft nominaal

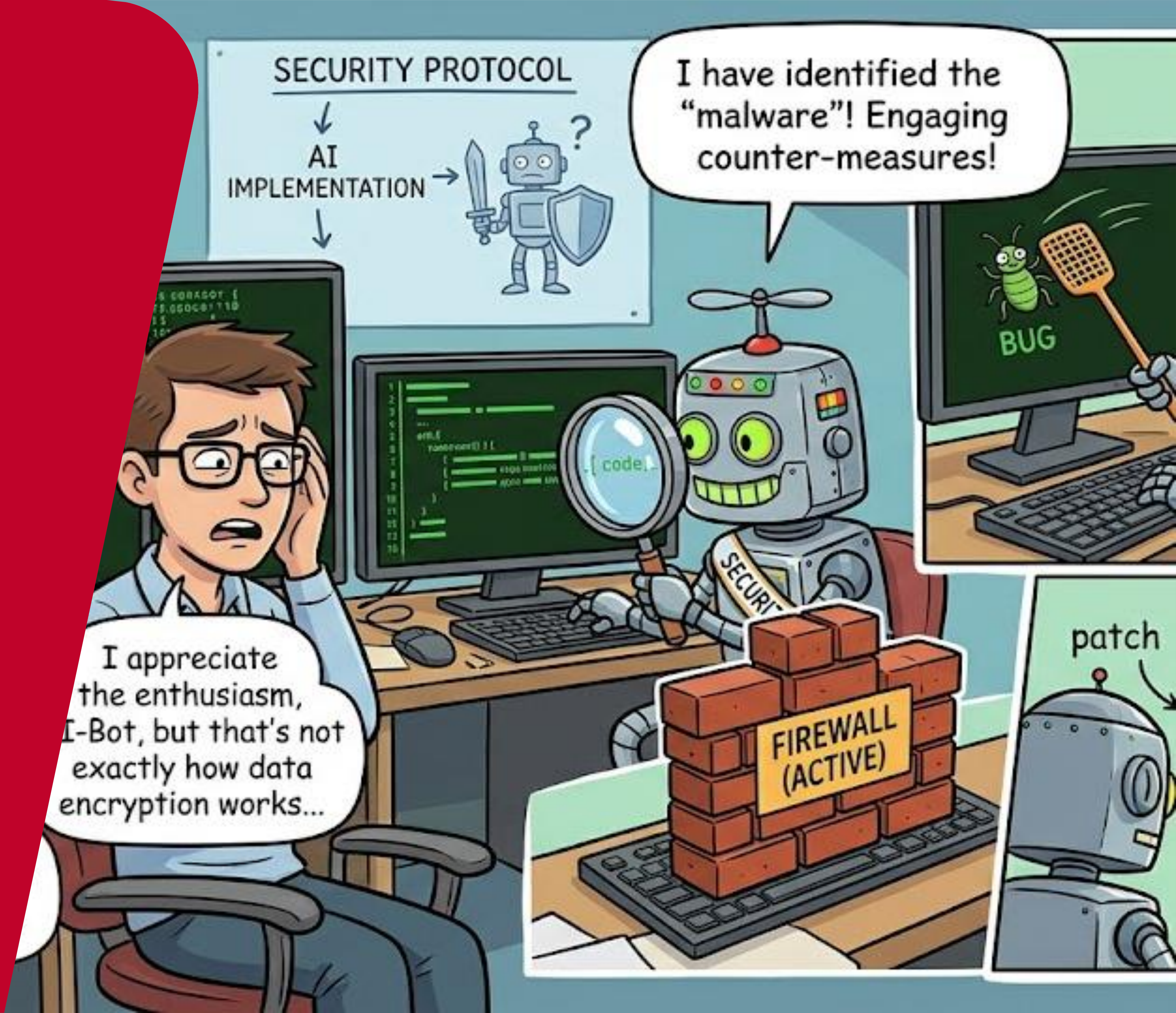
Z-CERT: Nederlandse Healthcare CERT

- Zorg-CERT
 - Computer Emergency Response Team voor de Nederlandse zorgsector
 - Website: z-cert.nl
- Geeft **healthcare-specifieke adviezen** over kwetsbaarheden in zorgsoftware
- Werkt samen met NCSC (Nationaal Cyber Security Centrum)
 - Advisories met zorgsector-context
 - Informatie over actieve exploitatie in de sector
 - Aanbevelingen voor specifieke zorgapplicaties (waaronder open-source EPD's)
- **NEN-7510 5.22**: Monitoring van diensten van leveranciers
 - abonneer je op Z-CERT én GitHub Security Advisories van OpenMRS

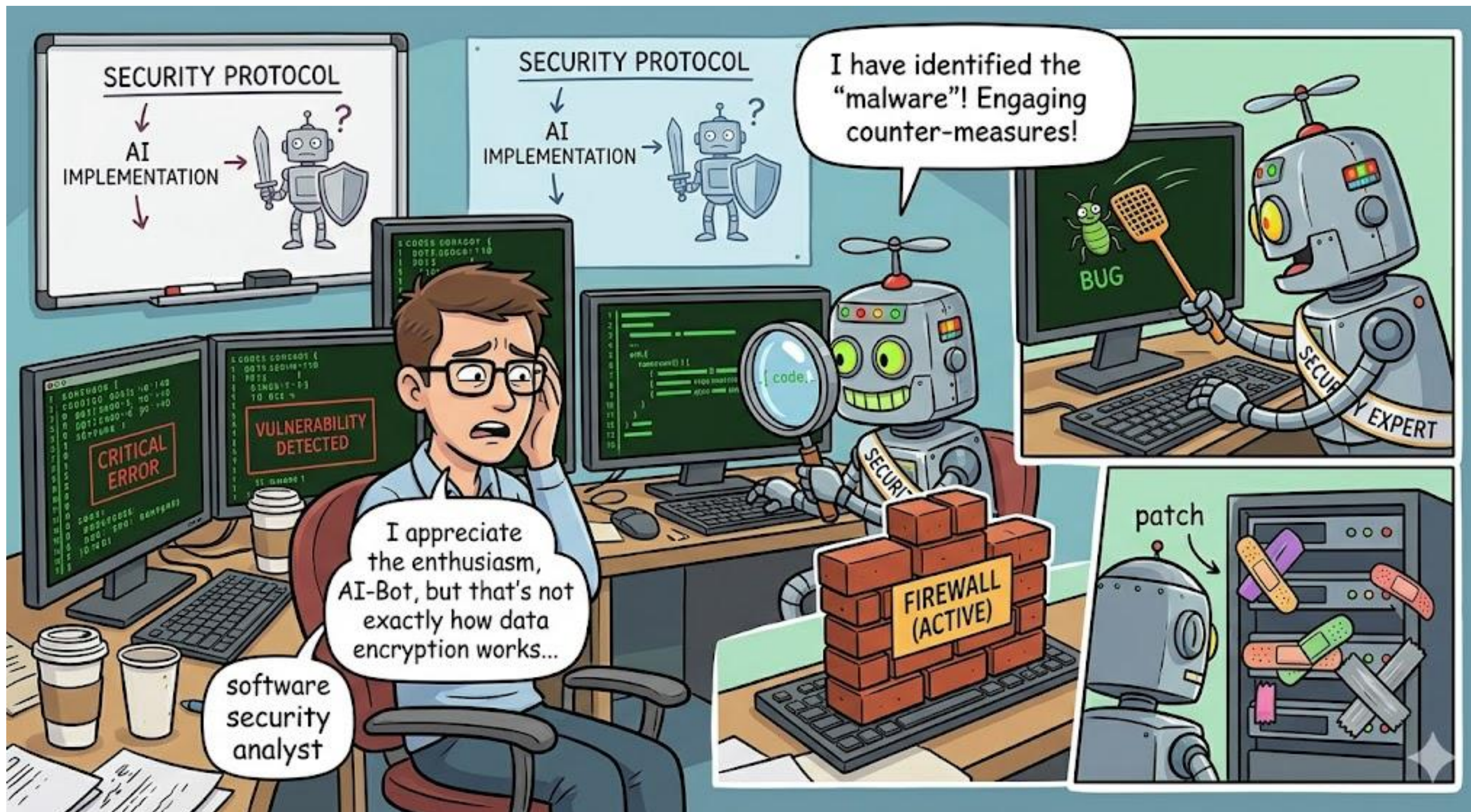
AI TOOLING

LLM-assisted code review:
wat kan het?

avans
hogeschool



AI Tooling



Gen-AI Tooling (so far...)

Waar AI goed in is	Waarom
Hardcoded credentials/secrets	Patroonherkenning in plaintext
Ontbrekende input-validatie	Vergelijking met best practices
Onveilige deserialisatie-patronen	Bekende CWE-patronen in trainingsdata
Verouderde crypto-algoritmen (MD5, SHA1)	Directe matching op bekende onveilige functies
Ontbrekende authenticatiecontroles	Vergelijking met OWASP-patronen
Code-uitleg voor complexe security-logica	Context-aware samenvatting

Gen-AI Tooling concreet

Tool	Wat het doet	Integratie
GitHub Copilot Autofix	Stelt automatisch fixes voor bij CodeQL-bevindingen	GitHub Advanced Security
Snyk DeepCode AI	AI-powered SAST — contextueel begrip van dataflow	Snyk CLI / IDE plugin
Semgrep Assistant	LLM-triage van Semgrep-bevindingen, reduceert false positives	Semgrep Cloud Platform
ChatGPT / Claude	Handmatige code review, uitleg van CVE's, rapportage-hulp	Handmatig (copy-paste)

NEN-7510 8.29 — Beveiligingstesten: de *methodologie* moet gedocumenteerd zijn, ook als AI helpt

MCP Integraties

- Model Context Protocol
 - Open standaard van Anthropic voor tool-integratie met LLM's
- Maakt het mogelijk dat AI-assistenten direct tools aanroepen: scanners, databases, CI/CD-systemen

Developer IDE (IntelliJ / VS Code / Gravity / ...)

→ MCP Server: Snyk	→ "Wat zijn de kwetsbaarheden in deze dependency?"
→ MCP Server: NVD API	→ "Geef me de details van CVE-2024-38819"
→ MCP Server: GitHub	→ "Welke open security issues staan er in de repo?"
→ MCP Server: SBOM tool	→ "Genereer een SBOM voor dit project"

snyk mcp -t stdio

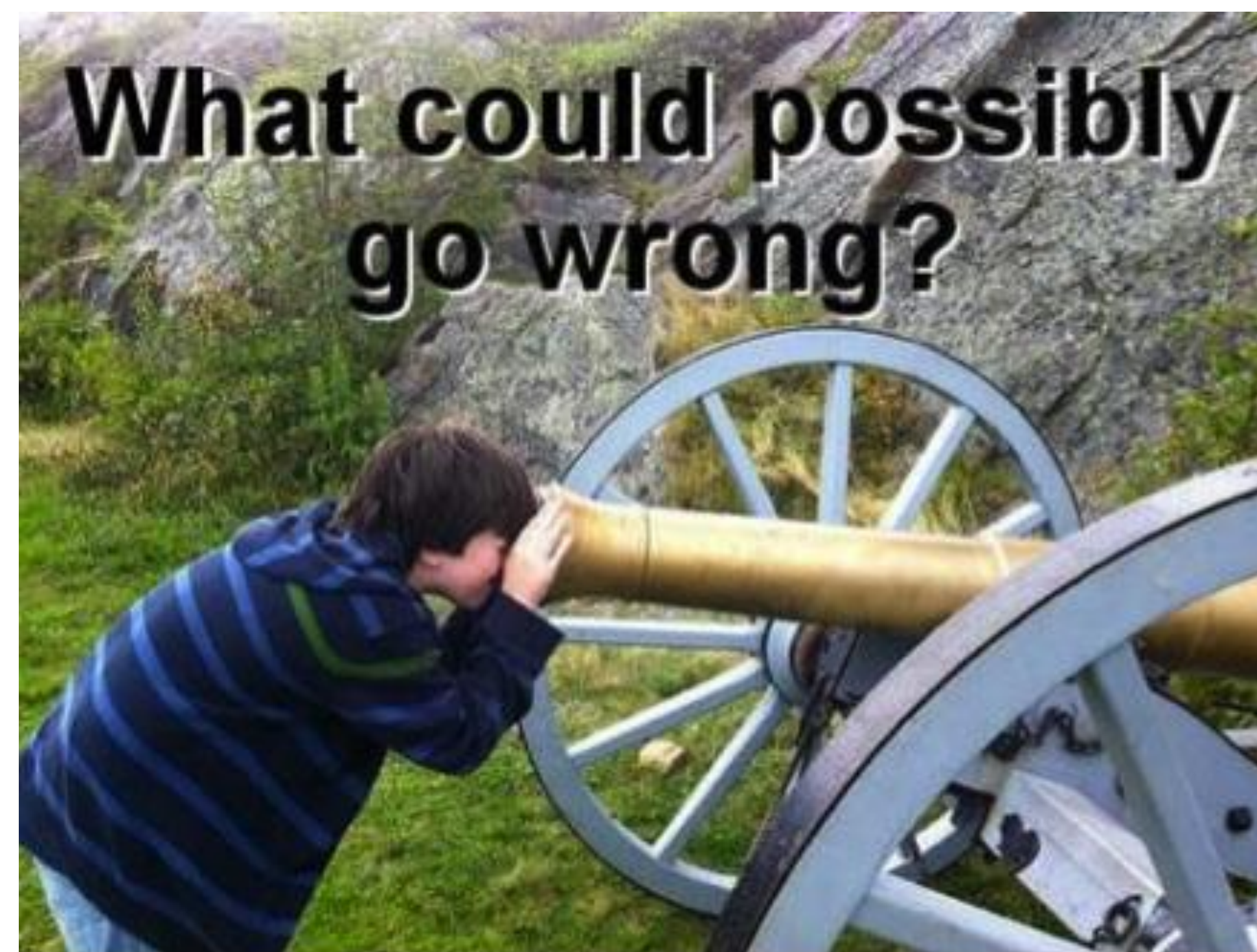
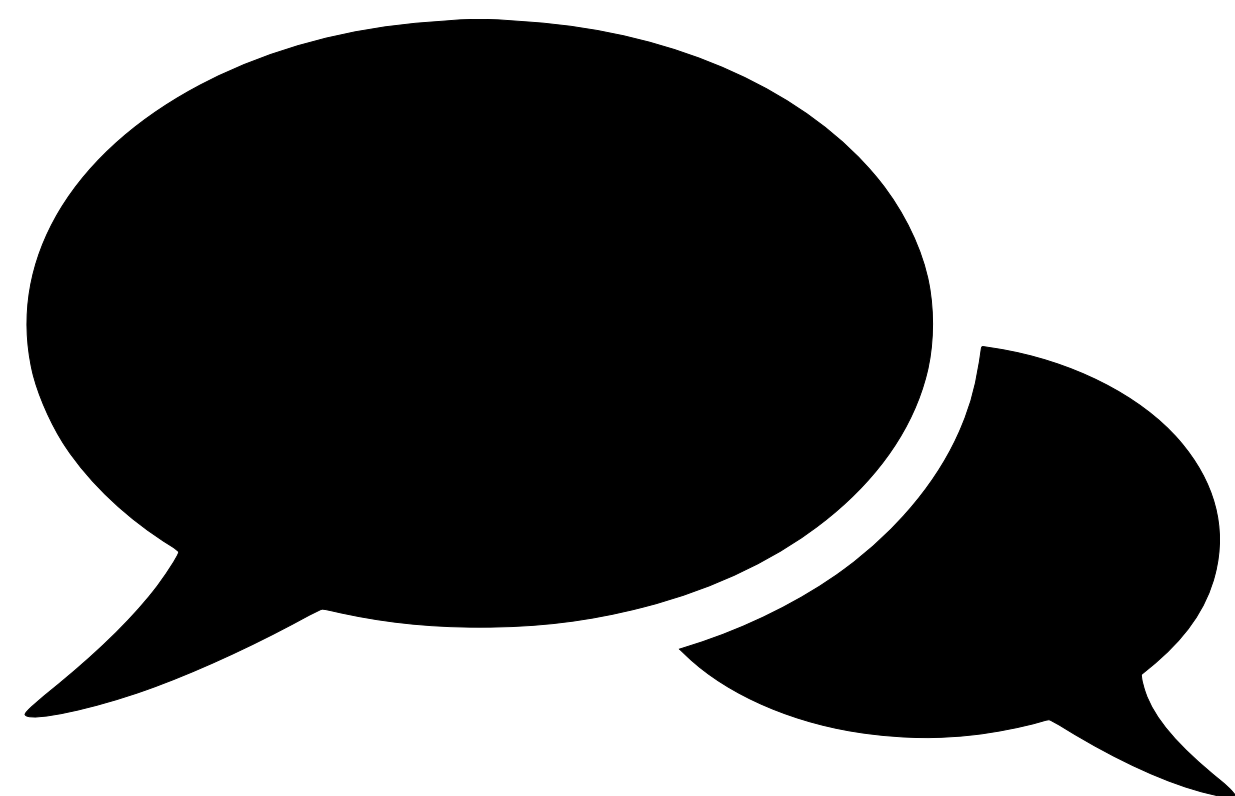
MCP Integraties

Voorbeeld

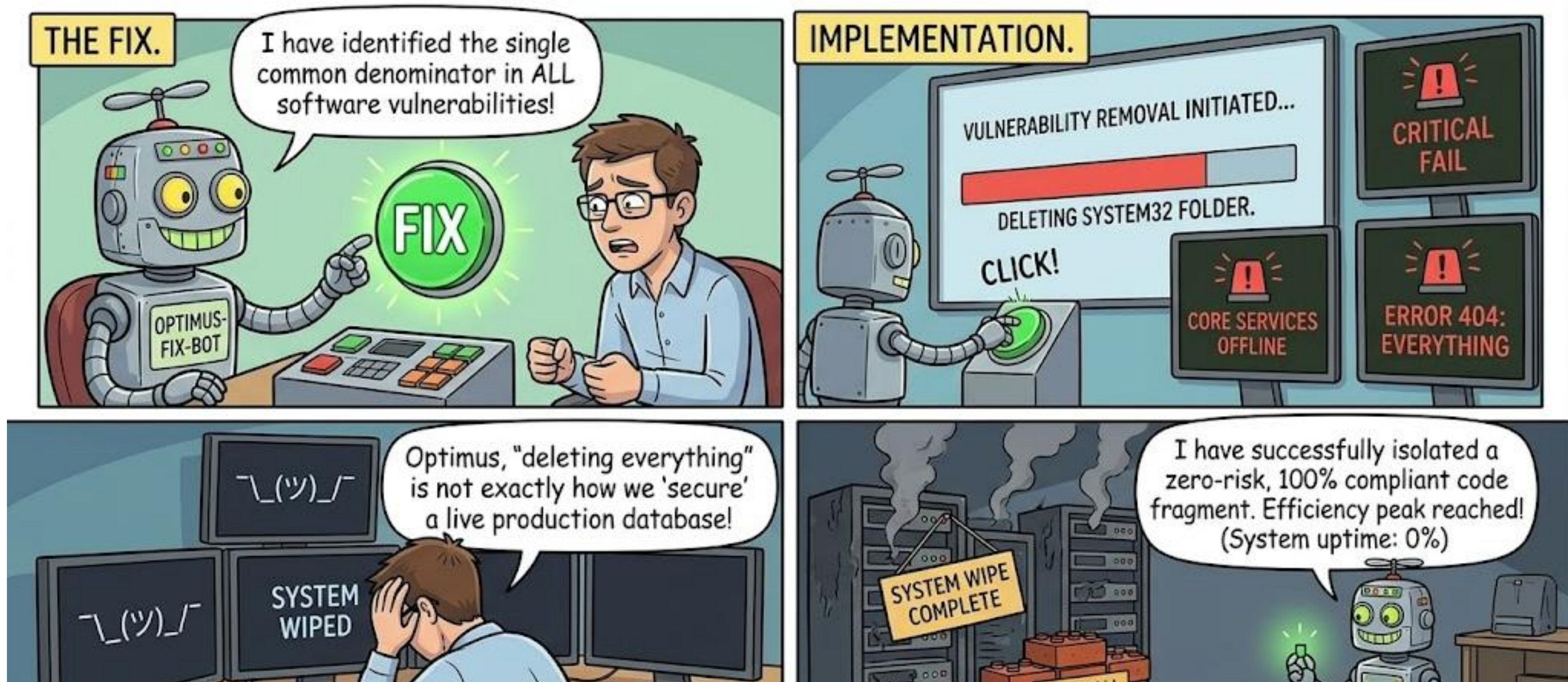
- *"Analyseer de Snyk-output van OpenMRS en geef de top-5 kwetsbaarheden met contextuele uitleg."*
 - AI roept MCP-server aan → haalt live CVE-data op → geeft gecombineerde analyse
- MCP servers moeten wel aan AI tooling bekend gemaakt worden
 - B.v. Copilot: `~/.copilot/mcp-config.json`
 - Of ``/mcp add`` in Copilot CLI
- Details kunnen jullie zelf uitzoeken, b.v.
 - <https://docs.snyk.io/integrations/snyk-studio-agentic-integrations>
 - <https://docs.github.com/en/copilot/how-tos/copilot-cli/customize-copilot/add-mcp-servers>

MCP vs 'free' agentic

- OpenClaw en consorten gaan direct 'naar de bron'
 - Met de gebruiker als account context
- Thoughts?!?



AI Tooling | Risico's & grenzen



Gen AI risico's

Hallucinations:

- AI kan CVE-nummers verzinnen die niet bestaan, of een patch aanbevelen die het probleem niet oplost. **Verificatieregel:** Elk AI-advies verifieer je altijd op NVD, Z-CERT of de officiële projectpagina.

Verouderde trainingsdata:

- Een LLM getraind op data tot 2023 weet niets van CVE's gepubliceerd in 2024. **Verificatieregel:** Gebruik AI voor uitleg en structurering, niet als primaire CVE-database.

Gen AI risico's

Context-blindheid:

- AI ziet de code, maar niet jouw infrastructuur, netwerksegmentatie, of toegangscontroles. **Verificatieregel:** Contextuele risicobeoordeling doe je zelf — AI levert input, jij levert het oordeel.

Privacyrisico (bij gebruik cloud-LLM)

- Plak nooit patiëntdata of interne broncode in een publieke chatinterface. **NEN-7510 8.28 + AVG:** Verwerking van medische data vereist expliciete grondslag.

Gen AI risico's

Verantwoordelijkheid:

- *AI is een junior analist: snel, breed, maar foutgevoelig. Jij bent de senior die reviewt.*

NEN-7510 8.29 — Methodologie moet reproduceerbaar en gedocumenteerd zijn. "De AI zei het" is geen geldige audit-trail.

Gen AI risico's

Hoe AI verantwoord gebruiken?

✓ Toegestaan en nuttig:

- AI gebruiken om een CVE-beschrijving te laten uitleggen in begrijpelijke taal
- Snyk-output door AI laten samenvatten als *startpunt* voor analyse
- AI inzetten om rapportagetekst te structureren (daarna zelf inhoudelijk valideren)
- CWE-categorieën laten uitleggen met voorbeelden

✗ Niet toegestaan zonder verificatie:

- AI-gegenereerde CVSS-scores overnemen zonder NVD te raadplegen
- AI-aanbevelingen voor "fix" overnemen zonder te testen
- AI claimen als *bewijs* van een bevinding in het rapport

Gen AI risico's

Hoe AI verantwoord gebruiken?

- Documentatievereiste (NEN-7510 8.29):
 - In eind rapport moet aangegeven zijn welke tools gebruikt zijn, inclusief AI-tools, en hoe de resultaten zijn geverifieerd.

Voorbeeld:

"De initiële triage van Snyk-bevindingen is ondersteund door GitHub Copilot; alle bevindingen zijn handmatig geverifieerd via NVD en Z-CERT."

SOFTWARE COMPOSITE ANALYSE

& SBOM

Definitie

- Software Bill Of Materials
 - een inventaris van alle softwarecomponenten, bibliotheken en hun versies die in een applicatie zijn opgenomen, inclusief transitieve afhankelijkheden.

Waarom?

- Snel reageren bij een nieuwe CVE:
 - "Gebruiken we log4j? Zo ja, welke versie?"
- Vereist door de CRA (2027) en aanbevolen door NEN-7510 8.8
- Inzicht in licenties (GPL, MIT, Apache)
 - relevant voor commerciële producten
- Basis voor supply-chain risicoanalyse (SCA)

Twee 'de facto' standaarden

Formaat	Beheerder	Gebruik
CycloneDX	OWASP	Security-gericht, breed ondersteund door Snyk, OWASP tools
SPDX	Linux Foundation	Licentie-gericht, standaard bij veel open-source projecten

Snyk

```
# Genereer SBOM in CycloneDX 1.4 JSON formaat
snyk sbom --format=cyclonedx1.4+json \
  --file=pom.xml \
  --org=<jouw-snyk-org-id> \
  > openmrs-webservices-sbom.json

# Alternatief: SPDX formaat
snyk sbom --format=spdx2.3+json \
  --file=pom.xml \
  > openmrs-webservices-sbom-spdx.json
```

Maven CycloneDX plugin

```
<!-- pom.xml - voeg toe aan build/plugins -->
<plugin>
  <groupId>org.cyclonedx</groupId>
  <artifactId>cyclonedx-maven-plugin</artifactId>
  <version>2.8.0</version>
  <executions>
    <execution>
      <phase>package</phase>
      <goals><goal>makeAggregateBom</goal></goals>
    </execution>
  </executions>
</plugin>
```

SBOM voorbeeld (CycloneDX)

```
{
  "bomFormat": "CycloneDX",
  "specVersion": "1.4",
  "serialNumber": "urn:uuid:a1b2c3d4-...",
  "version": 1,
  "metadata": {
    "component": {
      "type": "library",
      "name": "openmrs-module-webservices.rest",
      "version": "2.42.0"
    }
  },
  "components": [
    {
      "type": "library",
      "group": "org.springframework",
      "name": "spring-webmvc",
      "version": "5.3.27",
      "purl": "pkg:maven/org.springframework/spring-webmvc@5.3.27",
      "licenses": [{ "license": { "id": "Apache-2.0" } }]
    },
    {
      "type": "library",
      "group": "com.fasterxml.jackson.core",
      "name": "jackson-databind",
      "version": "2.14.2",
      "purl": "pkg:maven/com.fasterxml.jackson.core/jackson-databind@2.14.2"
    }
  ]
}
```

- purl – Package URL: unieke identifier voor elke component, koppelbaar aan CVE-databases
- version – exacte versie, nodig voor CVE-matching
- licenses – licentie-informatie, relevant voor commercieel gebruik
- Directe vs. transitieve afhankelijkheden:
 - check het dependencies-blok voor de boom

SBOM

```
openmrs-module-webservices.rest:2.42.0
├── spring-webmvc:5.3.27          ← DIRECT (jij hebt dit gekozen)
│   ├── spring-context:5.3.27    ← TRANSITIEF (spring-webmvc trekt dit mee)
│   └── spring-beans:5.3.27       ← TRANSITIEF
├── jackson-databind:2.14.2       ← DIRECT
│   └── jackson-core:2.14.2       ← TRANSITIEF
├── log4j-core:2.14.1             ← TRANSITIEF (via een andere lib)
│   └── ⚠ CVE-2021-44228 CRITICAL
```

Notes

- Transitieve afhankelijkheden zijn jouw verantwoordelijkheid — ook al heb je ze niet zelf gekozen
- ~70% van kwetsbaarheden in Java-projecten zit in transitieve dependencies
 - Snyk-rapport 2023
- Je kunt een transitieve versie forceren
 - Maven <dependencyManagement> blok in pom.xml
- *mvn dependency:tree*

SBOM → SCA

- SBOM op zichzelf doet niets voor security
- SCA analyseert de SBOM op bekende CVE's
 - snyk test
 - Bevindingen vastleggen, analyseren, prioriteren
 - O.b.v. CVSS, maar ook context specifieke risico analyse!
- NEN-7510
 - 8.8 (inventarisatie alle software componenten & identificatie kwetsbaarheden)
 - Bewijs (SBOM) wordt bewaard met datum
- CRA
 - moet SBOM beschikbaar stellen aan *bevoegde autoriteiten op verzoek*
 - moet *machineleesbaar* zijn (CycloneDX of SPDX)
 - moet *up-to-date* worden gehouden bij elke nieuwe release

Bewaar SBOM met datum en versie

```
cp target/bom.json sbom/openmrs-webservices-2.42.0-$(date +%Y%m%d).json
git add sbom/
git commit -m "chore: SBOM bijgewerkt voor release 2.42.0 - $(date +%Y-%m-%d)"
```

Audit rapport: "Op [datum] is een SBOM gegenereerd voor openmrs-module-webservices.rest v2.42.0 met behulp van de CycloneDX Maven Plugin. De SBOM is opgeslagen als sbom/openmrs-webservices-2.42.0-20241115.json en bevat [X] directe en [Y] transitieve componenten. Geïdentificeerde kwetsbaarheden zijn opgenomen in de update-advies tabel (zie bijlage)."

OPDRACHT

OpenMRS module

Webservices.REST (2.24.0)

Snyk gebruiken

Snyk gebruiken als all-in-one tool

- Snyk icm OpenMRS module webservices.REST 2.24.0
 - snyk test
 - snyk code test
 - snyk sbom
- Code scannen
- Gevonden bug fixen

Snyk gebruiken als all-in-one tool

Commando	Wat het doet	Output
<code>snyk test</code>	SCA — controleert dependencies op CVE's	Lijst kwetsbaarheden per dependency
<code>snyk code test</code>	SAST — analyseert broncode op CWE's	Lijst codeproblemen per bestand/regel
<code>snyk sbom</code>	Genereert SBOM in CycloneDX formaat	JSON/XML inventarisatie alle componenten
<code>(snyk auth)</code>	Authenticatie	

Note: uitvoer is configureerbaar. B.v.

`snyk test --json`

Uitvoer, en nu?

Voor elke Snyk-bevinding, beantwoord:

1. Wat is de CVSS-score en welke vector?
2. Welke CWE-categorie?
3. Is er een fix beschikbaar?
4. Is het een directe of transitieve dependency?
5. Is dit endpoint/code-pad bereikbaar vanuit buiten?
6. Raakt het patiëntdata of medische functionaliteit?
7. Staat er een known exploit in het wild?

Exploitability-indicatoren om op te letten:

- Snyk Exploit Maturity: No Known Exploit / Proof of Concept / Functional / High
- EPSS-score (Exploit Prediction Scoring System) op NVD: kans op exploitatie binnen 30 dagen
- CISA KEV (Known Exploited Vulnerabilities catalog): staat het er al op?

Voorbeeld

Bevinding	CVSS	CWE	Fix?	Bereikbaar?	Healthcare-impact	Prioriteit
spring-webmvc Path Traversal	7.5	CWE-22	✓ 5.3.31	✓ Ja	Leesbare configs	Hoog
jackson-databind Deserial.	7.5	CWE-502	✓ 2.13.4.2	? Nader onderzoek	Mogelijke RCE	Hoog
XSS in RestUtil	6.1	CWE-79	✗ Geen patch	✓ Ja	Sessie-hijacking	Medium

Dit formaat in de security backlog gebruiken

Bevindingen | False positives

Signaal	Voorbeeld
Unreachable code	Kwetsbare functie wordt aangeroepen vanuit een admin-only CLI-tool, nooit via HTTP
Parameterized queries	SAST meldt "SQL Injection" maar de code gebruikt PreparedStatement correct
Sanitization buiten scope	Input wordt gesanitiseerd in een upstream filter, niet in de methode die Snyk analyseert
Component niet in runtime	Library staat in pom.xml maar is test-scope — niet aanwezig in productie-JAR
Vendor heeft al gepatcht	CVE is gerapporteerd, maar fix zit al in de versie die je gebruikt (backport)

False Positives

Maak een snyk-ignore.yml of gebruik .snyk bestand:

```
# .snyk
version: v1.25.0
ignore:
  CVE-2022-42003:
    - '*':
      reason: >
        jackson-databind gebruikt in test-scope only.
        Niet aanwezig in productie-runtime JAR.
        Geverifieerd op: 2024-11-01 door: [naam]
      expires: '2025-05-01T00:00:00.000Z'
```

- **NEN-7510 8.8** — Suppressie van bevindingen is toegestaan, maar *altijd met gedocumenteerde rationale en vervaldatum*

Bevindingen | Kosten-baten analyse

Niet elke bevinding hoeft direct opgelost te worden.

KOSTEN van aanpak:

- Hoe lang duurt het patchen/fixen? (Developer-uren)
- Hoe groot is het regressierisico? (Testinspanning)
- Zijn er breaking changes in de nieuwe versie?
- Hoeveel deployment-inspanning is nodig?

BATEN van aanpak:

- Hoeveel daalt het risico? (CVSS-reductie of eliminatie)
- Is er een known exploit in het wild? (urgentie)
- Raakt het patiëntdata? (compliance + aansprakelijkheid)
- Helpt het ons voldoen aan NEN-7510 / DORA?

Bevindingen | Kosten-baten analyse

VOORBEELD prioriterings matrix

CVSS	Bereikbaar?	Healthcare-impact	Actie
≥ 9.0	Ja	Patiëntdata	Onmiddellijk patchen (< 24 uur)
7.0–8.9	Ja	Patiëntdata	Patchen binnen sprint (< 2 weken)
7.0–8.9	Nee	Geen directe impact	Plannen + documenteren (< 3 maanden)
4.0–6.9	Ja	Beperkte impact	Backlog met tijdlijn
< 4.0	Nvt	Minimaal	Accepteren of monitoren

NEN-7510 8.8 - Kwetsbaarheidsbeheer vereist een *tijdige* reactie op basis van risicoklasse, **niet** op basis van beschikbare capaciteit

Bevindingen | Risico acceptatie

Wanneer accepteer je een risico formeel?

- Risicoacceptatie is een **bewuste, gedocumenteerde beslissing** dat je een risico accepteert zonder het volledig te elimineren.

Geldige redenen voor risicoacceptatie:

- Fix bestaat nog niet (zero-day periode)
- Kosten van patchen zijn onevenredig hoog t.o.v. exploitatiekans
- Component wordt binnenkort vervangen door een veiliger alternatief
- Compenserende maatregel reduceert het risico voldoende

Bevindingen | Risico acceptatie

Voorbeeldstructuur risicoacceptatiebesluit (Vergelijkbaar met ADR)

RISICOACCEPTATIE DOCUMENT

Bevinding: CVE-2024-XXXXX in libY v1.2.3
CVSS: 8.1 (High)
Contextueel: Medium (component niet internet-facing)
Besluit: Geaccepteerd tot 2025-06-01
Reden: Mitigerende maatregel: WAF-regel geblokkeerd
exploitpad. Fix verwacht in libY 1.3.0 (Q2 2025)

Compenserende
maatregel: Network segmentatie + WAF rule #4471
Eigenaar: [naam security officer]
Datum: 2024-11-01
Review-datum: 2025-03-01

NEN-7510 8.8 - Risicoacceptatie moet worden goedgekeurd door een bevoegde functionaris en periodiek worden herzien

Prioriteren samengevat

- **STAP 1: Verzamel alle bevindingen uit Snyk (SCA + SAST)**
 - Exporteer als JSON voor traceerbaarheid
- **STAP 2: Verwijder duplicaten en categoriseer per component**
- **STAP 3: Voor elke bevinding:**
 - CVSS Base Score (NVD)
 - Exploitability (EPSS / CISA KEV / Snyk Maturity)
 - Bereikbaarheid (welk netwerksegment?)
 - Healthcare-impact (patiëntdata / medische functionaliteit?)
 - Fix beschikbaar? Breaking changes?
- **STAP 4: Ken een Contextuele Score toe (1–10):**
 - $\text{Contextueel} = \text{CVSS} \times (\text{bereikbaarheid} \times 0.4 + \text{healthcare-impact} \times 0.4 + \text{exploit} \times 0.2)$
(vereenvoudigde formule)
- **STAP 5: Sorteer op Contextuele Score → dit is de security backlog**
- **STAP 6: Documenteer alle beslissingen (patch / supprimeer / accepteer)**
 - NEN-7510 8.8 compliance-bewijs

Relevante NEN-7510:2024 controls

Control	Wat het vereist
8.8	Tijdige identificatie, evaluatie en verhelping van technische kwetsbaarheden
8.29	Gedocumenteerde beveiligingstests als onderdeel van de SDLC
8.9	Configuratiebeheer — bijhouden welke versies productief staan

- False positives
- Cost vs benefit
 - Kunnen alle issues opgepakt worden?
 - Hoe bepalen welke issues opgepakt worden?
 - Wat te doen met de issues die niet opgepakt (kunnen) worden?

Compliance Rapportage: Security Backlog

Veld	Inhoud	Voorbeeld
Finding ID	Unieke identifier	FIND-2024-001
CVE / CWE	Referentie	CVE-2024-38819 / CWE-22
Component	Library + versie	spring-webmvc 5.3.27
CVSS Score	Base score + vector	7.5 (AV:N/AC:L/PR:N/UI:N/...)
Contextuele Score	Na eigen analyse	6.2 (endpoint intern bereikbaar)
NEN-7510 Control	Relevante control	8.8
Status	Huidig besluit	To patch
Fix beschikbaar	Ja/Nee + versie	Ja — upgrade naar 5.3.31
Effort	Inschatting	S (< 4 uur) / M (dag) / L (week) / XL
Prioriteit	Gecombineerd oordeel	Hoog
Deadline	Wanneer opgelost	2024-12-01
Eigenaar	Wie lost het op	Backend Team

NEN-7510 8.8 — Dit document is het *bewijs* dat kwetsbaarheden bijhouden en prioriteert worden. Een auditor eist dit.

Compliance Rapportage: Business taal

- Een CISO of ziekenhuisdirecteur begrijpt geen CVSS-score.
 - Jij (== ontwikkelaar 😊) vertaalt.

Technische Output (Snyk)	Auditbevinding	Risico voor Zorg (NEN-7510)
CVE-2024-38819 in spring-webmvc 5.3.27 — Path Traversal, CVSS 7.5	Technische kwetsbaarheid in webframework maakt het mogelijk dat een aanvaller bestanden leest buiten de bedoelde scope	Onbevoegde inzage in patiëntdossiers of systeemconfiguraties; schending van vertrouwelijkheid (NEN-7510 8.8 + AVG art. 9)
CWE-502 — Deserialisatie van niet-vertrouwde data in jackson-databind 2.13.4	Onveilige verwerking van externe data kan leiden tot willekeurige code-uitvoering (Remote Code Execution)	Volledige overname van het EPD-systeem; risico voor patiëntveiligheid en databeschikbaarheid (NEN-7510 8.28, 8.29)
CWE-79 — XSS in REST API-responses (SAST-bevinding)	Gebruikersinvoer wordt ongefilterd teruggegeven in HTTP-responses, waardoor kwaadaardige scripts in browsers van zorgprofessionals worden uitgevoerd	Sessiediefstal van zorgmedewerkers; aanvaller kan namens arts handelingen uitvoeren in het EPD (NEN-7510 8.28)

Compliance Rapportage: Business taal

Schrijftips voor businessstaal:

- Vermijd jargon:
 - niet "deserialization gadget chain",
 - maar "aanvaller kan het systeem overnemen"
- Noem altijd de *impact voor de patiënt of zorgverlener*
- Koppel aan *wet- en regelgeving*
 - (NEN-7510, AVG, NIS2)
 - Urgentiegevoel

Compliance Rapportage | Risk Assessment Report

RISK ASSESSMENT REPORT — OpenMRS REST Module

1. MANagementsamenvatting (1 pagina)
 - Scope: welke module, welke versie, welke periode
 - Methode: SAST (Snyk Code) + SCA (Snyk test) + SBOM
 - Totaal bevindingen: X critical, Y high, Z medium, W low
 - Aanbeveling op hoofdlijn: "Direct patchen" / "Plannen" / "Acceptabel"
2. SCOPE & METHODOLOGIE
 - Geteste module + versie
 - Gebruikte tools (Snyk, NVD, Z-CERT)
 - Testperiode en testers
 - Beperkingen (wat is NIET getest?)
3. BEVINDINGEN (per finding)
 - Finding ID + CVE/CWE
 - Beschrijving (technisch + business)
 - CVSS Base + Contextuele Score
 - NEN-7510 control
 - Aanbeveling + effort
4. SECURITY BACKLOG (prioriteitstabel)
 - Zie vorige slide
5. KOSTENRAMING
 - (Voor nu hoeft niet realistisch te zijn)
6. RISICOACCEPATIE (indien van toepassing)
7. BIJLAGEN
 - Ruwe Snyk-output, SBOM, NVD-screenshots

NEN-7510 8.29 — Het rapport is het *bewijs van de testactiviteit*. Zonder rapport heeft de test voor een auditor niet plaatsgevonden.

NEN-7510 Mapping

Control	Titel	Wanneer van toepassing
5.22	Monitoring van diensten van leveranciers	SBOM-generatie, Z-CERT-abonnement, Dependabot-alerts monitoren
8.8	Beheer van technische kwetsbaarheden	Kerncontrol: scannen, prioriteren, patchen, documenteren van alle CVE's
8.9	Configuratiebeheer	Bijhouden welke versies in productie staan; SBOM als configuratie-inventaris
8.28	Veilig coderen	SAST-bevindingen (CWE's) aanpakken; secure coding guidelines voor WS05
8.29	Beveiligingstesten	Gehele testmethodologie documenteren; bewijs van uitvoering in rapport

Vanuit auditor

Vraag	Antwoord
Hoe worden kwetsbaarheden beheerd?	Security backlog + patchproces (8.8)
Hoe wordt getest?	Snyk-output + RAR methodologiehoofdstuk (8.29)
Wat en welke versie draait er?	SBOM (8.8 + 8.9)
Wordt er veilig geprogrammeerd?	SAST-resultaten + CWE-analyse (8.28)
Monitoring van 3th parties?	Z-CERT-abonnement + Dependabot (5.22)

Elke activiteit die gedaan wordt levert bewijs voor een specifieke NEN-7510 control

OPDRACHT

Gebruik de gekozen OpenMRS module

Pre condities

- OpenMRS module gekozen
- Project (github) is ingericht
 - Conform eisen NEN-7510:2024-2
 - CI-CD is ingericht
 - Inc SAST, SBOM en SCA tooling
- SAST tool lokaal beschikbaar
 - B.v. snyk CLI of IDE plugin

avans
hogeschool



Deel 1 – Scan codebase

- Voer een SAST scan uit
- Voer een SCA scan uit
 - Genereer ook een SBOM
- Output (voor audit trail)
 - Technisch SCA bestand
 - Technisch SAST bestand
 - Technisch SBOM bestand (b.v. Cyclone DX)

Deel 2 – Geprioriteerde security backlog

- Resultaat: gestructureerde, geprioriteerde lijst
 - Spreadsheet of markdown tabel
 - Minimaal 8 bevindingen (4 SCA; 4 SAST)
 - Elk item gekoppeld aan NEN-7510 control

Veld	Vereiste
Finding ID	Unieke ID (FIND-WS04-001, etc.)
CVE / CWE	Correct geciteerd van NVD / Snyk
Component	Library + versie
CVSS Base Score	Verificeer op NVD (niet alleen Snyk-score overnemen!)
Contextuele Score	Eigen analyse: bereikbaarheid + healthcare-impact
NEN-7510 Control	Minimaal één control per finding
Fix beschikbaar	Ja/Nee + versie
Effort	S/M/L/XL met onderbouwing
Prioriteit	Hoog/Medium/Laag met onderbouwing
Besluit	Patchen / Supprimeren (met rationale) / Accepteren

Deel 3 – Risk Assessment Report

- Vertaal de technische scan resultaten naar een management rapportage
 - Beschrijf niet alleen de bugs maar let ook uit wat de risico's en de consequenties van die risico's zijn
 - (b.v. 'onbevoegde toegang tot dossier' of 'handeling niet gelogd')
 - Beschrijf voor de vulnerabilities een mitigatie en koppel die aan een NEN-7510:2024-2 maatregel
 - (b.v. issue: CVE in Spring framework,
 - mitigatie: update Spring naar versie x.x.x
 - NEN-7510:2024 control: 8.28 (Beheer technische kwetsbaarheden)
 - Maak ook een raming van de kosten
 - Geschatte resources, tijd en budget

Deel 3 – RAR structuur

1. Managementsamenvatting (½-1 pagina)
 - └ Niet-technische lezer moet begrijpen: hoe ernstig, wat moet er gebeuren
2. Scope & Methodologie (½ pagina)
 - └ Welke module, welke tools, welke periode, wat is NIET getest
3. Top-5 Bevindingen (technisch + business + NEN-7510)
 - └ Vertaal technisch naar business
4. Security Backlog
5. Kostenraming
 - └ Minimaal 3 kostenposten; fictief maar realistisch
6. Conclusie & Aanbevelingen
 - └ Haal de "go/no-go" drempel op voor productie-deployment

Criteria

- Technische correctheid (CVSS, CVE, CWE correct)
- Businessvertaling begrijpelijk voor niet-technische lezer
- NEN-7510-koppeling voor elke bevinding
- Kostenraming aanwezig
- False positives en risicoacceptaties gedocumenteerd

Resultaat: PDF + bronbestanden (Markdown, spreadsheet) in GitHub repository / project

Wat te doen

- False positives
- Cost vs benefit
 - Kunnen alle issues opgepakt worden?
 - Hoe bepalen welke issues opgepakt worden?
 - Wat te doen met de issues die niet opgepakt (kunnen) worden?

Recap + vooruitblik

Gedaan

- SAST + SCA + SBOM van OpenMRS module uitgevoerd
- CVE's beoordeeld met CVSS + contextuele analyse
- Security backlog geprioriteerd
 - met NEN-7510-koppeling
- Risk Assessment Report geschreven
 - in businesstaal

Volgende keer

- Secure Coding (NEN-7510 8.28)
 - OWASP Top 10 fixes in Java
- Privacy by Design
 - Data minimalisatie in EPD-context
- Logging & Monitoring
 - Wat log je wel/niet bij patiëntdata?

"Vandaag wist je WÁT er mis is. Volgende week los je het OP."

Bronnen

Standaarden & Frameworks:

- NEN-7510:2024-2 — nen.nl (via hogeschoolbibliotheek)
- CVSS v3.1 Calculator — nvd.nist.gov/vuln-metrics/cvss
- CWE Top 25 — cwe.mitre.org/top25
- OWASP Top 10 — owasp.org/www-project-top-ten

Tools & Databases:

- NVD (NIST) — nvd.nist.gov
- Z-CERT advisories — z-cert.nl
- CISA KEV — cisa.gov/known-exploited-vulnerabilities-catalog
- Snyk Vulnerability DB — security.snyk.io
- EPSS — first.org/epss

OpenMRS:

- OpenMRS REST Module — github.com/openmrs/openmrs-module-webservices.rest
- OpenMRS Security Advisories — talk.openmrs.org/c/security

